



Sicurezza e Affidabilità



Agenda della seconda parte del corso

■ Programma

- ➔ Crittografia
- ➔ Sicurezza nelle reti
- ➔ Sicurezza nei sistemi operativi
- ➔ Sicurezza nelle applicazioni

■ Lab

- ➔ Venerdì 24/04 Lab su Selenium
- ➔ **Giovedì 30/04** Lab su crittografia e firma digitali
- ➔ Venerdì 08/05 Lab su password cracking
- ➔ Venerdì 15/05 Lab su analisi del traffico di rete

■ Interventi esterni

- ➔ Venerdì 22/05 OSINT (Bip)
- ➔ Venerdì 29/05 DevSecOps (Moviri)
- ➔ Venerdì 05/06 Cybersec & AI (Moviri)

Security is not Safety

- **Safety engineering:** prevenzione di danni “catastrofici” causati dal cattivo funzionamento di un sistema informatico
 - ➔ Sistemi life critical
 - ➔ Sistemi avionici
 - ➔ Controllori di centrali nucleari
 - ➔ ...
- **Security engineering:** prevenzione, difesa e recupero danni contro la possibilità di attacchi (più o meno diretti) che possono mettere a repentaglio i valori rappresentati da un sistema informatico
- **Tutte le misure di safety sono anche misure di sicurezza, ma non è vero il viceversa**

Principio base

- Un problema di sicurezza, o vulnerabilità, può essere in generale inteso come una...

...via alternativa

- Quando il sistema è complesso:

Le vie "alternative"
possono essere moltissime



Door opening mechanism

Safety Requirement

Doors shall open when car is flipped



Door opening mechanism

Safety Requirement

Doors shall open when car is flipped

Solution

Install pressure sensor at the roof of the car



Door opening mechanism

Safety Requirement

Doors shall open when car is flipped

Solution

Install pressure sensor at the roof of the car

Solution has serious security consequences

Unauthorized entry by jumping on the car



Requisiti per la sicurezza (CIA Triad)

■ Tre obiettivi fondamentali:

⇒ Confidenzialità (Confidentiality)

⇒ Integrità (Integrity)

⇒ Disponibilità (Availability)

The CIA Triad

■ ■ *Confidentiality*

➞ Ensuring that information is accessible only to those authorized

■ ■ *Integrity*

➞ Ensuring that information has not been modified

■ ■ *Availability*

➞ Legitimate users have access when they need it

Requisiti per la sicurezza: Confidenzialità

- Capacità di controllare/assicurare **la riservatezza** delle informazioni archiviate/trasmesse rispetto a soggetti non autorizzati

Requisiti per la sicurezza: Confidenzialità

■ Esempi di possibili compromissioni

- ➔ Accesso a dati il cui contenuto non deve essere noto
- ➔ Visibilità dell'esistenza di oggetti la cui esistenza non deve essere nota
- ➔ Analisi del traffico di una rete
- ➔ ...

Requisiti per la sicurezza: Integrità

■ Capacità di controllare/assicurare la

- non modificabilità

- attendibilità

da parte di soggetti non autorizzati delle informazioni memorizzate/trasmesse

Requisiti per la sicurezza: Integrità

■ Esempi di possibili compromissioni

- ➔ Modifica non autorizzata di un oggetto
(es. scrittura su oggetti accessibili in sola lettura)
- ➔ Cancellazione non autorizzata di un oggetto
- ➔ Creazione non autorizzata di un oggetto
- ➔ Manomissione di informazioni sensibili
- ➔ Manomissione di un software/hardware
- ➔ ...

Firma digitale (integrità)

- Per i dati coinvolti in attività di comunicazione può nascere l'esigenza di garantire
 - ➞ Autenticità del mittente
 - Capacità di garantire l'identità del mittente delle informazioni trasmesse/archivate
 - ➞ Non-ripudio
 - Capacità di assicurare che il mittente non possa negare la paternità delle informazioni archiviate/trasmesse.

Requisiti per la sicurezza: Disponibilità

- Capacità di controllare/assicurare **la possibilità di usare** risorse e dei servizi agli utenti autorizzati

Requisiti per la sicurezza: Disponibilità

■ Esempi di possibili compromissioni

- ➔ Causare un crash di sistema
- ➔ Manomettere gli algoritmi di scheduling
- ➔ Saturare la banda di rete per impedire o rallentare gli accessi a un servizio (DoS: Denial of Service)
- ➔ Compromettere un file di password per evitare l'accesso degli utenti autorizzati all'uso del sistema
- ➔ Distruzione fisica di un computer
- ➔ ...

DAD vs CIA

■ Attacks on the CIA are typically referred to as *DAD*:

➡ **D**isclosure > **C**onfidentiality

➡ **A**lteration > **I**ntegrity

➡ **D**estruction > **A**vailability

Ostacoli all'implementazione della sicurezza

■ Dilemma: usability vs. security

- ➞ L'obiettivo di fondo dell'informatica e dell'ingegneria del software è favorire quanto più possibile l'accesso alle risorse
- ➞ La sicurezza obbliga a limitare l'accesso alle risorse
 - es. l'autenticazione tramite password può essere vista come un fastidio per molti utenti

■ Progetto tardivo

- ➞ Spesso la sicurezza viene presa in considerazione solo dopo il verificarsi dei primi incidenti

■ Necessità di compromesso fra benefici e costi

- ➞ I sistemi di sicurezza costano e non sempre *stanno nel budget*

⇒ Una corretta analisi dei rischi diventa fondamentale

Analisi dei rischi

Dizionario: Rischio = “**possibilità di perdita o danno**”

In ambito sicurezza informatica

$$R \text{ (rischio)} = \text{Vulnerabilità} \times \text{Minacce} \times \text{Valori}$$

■ Valori sensibili

➞ Quali parti del sistema informativo sono importanti/sensibili/critiche?

➤ elementi da proteggere + loro relativa importanza

■ Vulnerabilità

➞ In cosa siamo vulnerabili?

➤ Debolezze/attacchi che possono essere sfruttati per compromettere la confidenzialità, l'integrità o la disponibilità di valori sensibili

■ Minacce

➞ Quali sono i pericoli cui siamo esposti?

➤ circostanze o agenti che possono arrecare danni

Gestione dei Rischi

